

Vulnerability Assessment Report

Target: scanme.nmap.org · IP: 45.33.32.156

Prepared by Nishant · Authorized scan · Passive assessment only

7

Total findings

3

Medium risk

3

Low risk

0

Critical / High

ABOUT THE TARGET

What is scanme.nmap.org?

This is a practice server set up and maintained by the Nmap Security Scanner Project. It exists specifically so that people learning network security can practice their scanning skills in a legal, controlled environment.

The site itself says: "You are authorized to scan this machine with Nmap or other port scanners." — so everything we did here is completely above board.

No real user data or production systems were involved in this assessment.

TARGET DETAILS	
URL	http://scanme.nmap.org
IP Address	45.33.32.156
OS	Linux (Ubuntu)
Web Server	Apache 2.4.7
SSH Server	OpenSSH 6.6.1p1
Assessment Type	Passive — no exploitation
Authorization	Publicly granted by Nmap

HOW WE SCANNED

Three-phase passive methodology

No active attacks were performed. All scanning was read-only and non-intrusive.

01

Network Recon

Nmap 7.99

We ran `nmap -Pn -sV -sC` against the target to find open ports, identify what services are running, and detect software versions. This tells us the server's exposed surface.

02

Web App Scan

OWASP ZAP 2.17.0

We pointed ZAP at the website and let it passively spider all 13 pages it could find. ZAP analyzed every HTTP response for missing security headers and known misconfiguration patterns.

03

Header Inspection

Browser DevTools

We loaded the site in Chrome, opened DevTools, and exported a HAR file. This gave us a clean record of every HTTP header the server sent — and, more importantly, what it didn't send.

NMAP SCAN RESULTS

Open ports found

 **Port 22 · SSH**
OpenSSH 6.6.1p1

 **Port 80 · HTTP**
Apache 2.4.7 (Ubuntu)

 **Port 9929 · nping-echo**
Nping echo service

 **Port 31337 · tcpwrapped**
Wrapped / filtered

+ 13 filtered ports blocked by firewall

Command: `nmap -Pn -sV -sC scanme.nmap.org`

What this means in plain English

Outdated SSH

OpenSSH 6.6.1p1 is from 2014. The current version is 9.x. Running old SSH means the server may be vulnerable to exploits that have been patched in newer releases.

Outdated Apache

Apache 2.4.7 is from 2013 and has multiple known CVEs. Simply knowing the exact version (which the server advertises) helps attackers pick the right exploit.

Firewall in place

The 13 filtered ports show a firewall is blocking unused services. This is good — it reduces how much of the server is reachable from the internet.

Port 31337 note

This port has a hacker-culture history, but on this authorized test server it's likely intentional. Worth flagging for awareness.

7 alerts found across 13 endpoints



#	Alert	Risk	Confidence	CWE
1	Content Security Policy (CSP) Header Not Set	Medium	High	CWE-693
2	Missing Anti-Clickjacking Header	Medium	Medium	CWE-1021
3	Sub Resource Integrity Attribute Missing	Medium	High	CWE-345
4	In-Page Banner Information Leak	Low	High	CWE-497
5	Server Version Disclosure via HTTP Header	Low	High	CWE-497
6	X-Content-Type-Options Header Missing	Low	Medium	CWE-693
7	Modern Web Application (informational only)	Info	Medium	–

DETAILED FINDINGS

Finding 1: CSP Header Not Set

Medium

CWE-693

The server doesn't send a Content-Security-Policy header with its responses. This header is what tells a browser which scripts and resources are allowed to run on the page. Without it, if an attacker ever gets malicious code onto the page, the browser has no policy to stop it from executing.

BUSINESS IMPACT

Opens the door to Cross-Site Scripting (XSS) attacks. An attacker could steal user session cookies or redirect visitors to fake pages.

FIX

Opens the door to Cross-Site Scripting (XSS) attacks. An attacker could steal user session cookies or redirect visitors to fake pages.

Finding 2: Missing Anti-Clickjacking Header

Medium

CWE-1021

There's no X-Frame-Options header. Without it, any website on the internet can embed this page silently inside an invisible iframe. Attackers use this to trick users into clicking things they can't see — a technique called clickjacking.

BUSINESS IMPACT

Users can be tricked into submitting forms, clicking buttons, or performing actions they never intended — all while seeing a completely different page.

FIX

Add to Apache config: Header always set X-Frame-Options DENY

DETAILED FINDINGS (CONT.)

Finding 3: SRI Attribute Missing

Medium

CWE-345

The page loads a Google Analytics script from an external server, but doesn't include an integrity hash. Subresource Integrity (SRI) is how browsers verify that a third-party file hasn't been secretly modified since the developer last reviewed it.

BUSINESS IMPACT

If Google's CDN or the analytics provider were ever compromised, an attacker could push modified JavaScript to every visitor of this site — and the browser would load it with full trust.

FIX

Generate a hash at srihash.org and add it as an integrity attribute to the script tag. Example: `integrity="sha384-abc123..."`

Finding 4: Server Version Disclosure

Low

CWE-497

Every HTTP response includes a Server header that says exactly what software is running: Apache/2.4.7 (Ubuntu). Even 404 error pages announce this in the page body. Attackers don't need to guess — the server tells them.

BUSINESS IMPACT

Knowing the exact server version lets attackers search for known CVEs specific to that version. It cuts down their research time significantly and helps them pick targeted exploits.

FIX

In Apache config, set: `ServerTokens Prod` and `ServerSignature Off`. This reduces the Server header to just "Apache" with no version.

DETAILED FINDINGS (CONT.)

Finding 5: Error Page Banner Leak

Low

CWE-497

When you visit a page that doesn't exist (like /sitemap.xml), the server returns a 404 page that includes: Apache/2.4.7 (Ubuntu) Server at scanme.nmap.org Port 80. This is in the visible page body — not just a header.

BUSINESS IMPACT

Anyone who triggers an error page, even accidentally, gets a detailed fingerprint of the server software. Combined with Finding 4, an attacker has a very clear picture of the technology stack.

FIX

Create a custom 404 page with a friendly message that reveals nothing about the server. In Apache: ErrorDocument 404 /custom-404.html

Finding 6: X-Content-Type-Options Missing

Low

CWE-693

The server doesn't send the X-Content-Type-Options: nosniff header. This header stops browsers from guessing (or "sniffing") what type of content a file is. Without it, a browser might run a text file as a script if it looks like JavaScript.

BUSINESS IMPACT

Old browser versions could interpret and execute files in ways the server didn't intend. This is less of a risk in modern browsers but is still considered a required security baseline by most compliance standards.

FIX

Add to Apache config: Header always set X-Content-Type-Options nosniff. One line, takes effect immediately after an Apache restart.

ACTION PLAN

All 6 issues can be fixed with server config changes

No code changes required. Everything is an Apache configuration directive.

#	Finding	Priority	Apache fix (one line)
1	CSP Header Not Set	Medium	Header always set Content-Security-Policy "default-src 'self'"
2	Anti-Clickjacking Header Missing	Medium	Header always set X-Frame-Options DENY
3	SRI Attribute Missing	Medium	Add integrity hash to all external

CONCLUSION

No critical issues — but there's a clear baseline to improve.

scanme.nmap.org is a practice server, so we weren't expecting a perfectly locked-down system. What this assessment shows is a very common pattern you see on real websites too — the core functionality works fine, but several quick security improvements have been left on the table.

The good news: every single finding here is fixable in an afternoon. None of them require a developer, and none of them require taking the site down.

They're all Apache configuration one-liners.

KEY TAKEAWAYS

- No critical or high risk findings identified
- 3 medium-risk missing security headers found
- Server is broadcasting its exact version — easy recon for attackers
- All issues are Apache config changes — no dev work needed
- A firewall is in place, which is a positive security control
- Outdated software versions (SSH, Apache) should be updated